

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

GRC102: INFORMATION SECURITY GOVERNANCE

ASSIGNMENT 1

Principles of Information Security Governance

Course Week	Week 1	Assessment Type	Individual Assignment
Opens	05 Sep 2026, 8:00 AM WAT	Deadline	11 Sep 2026, 11:59 PM WAT
Maximum Score	100 points	Gradebook Weight	8.75% of final course grade

Overview

This assignment reinforces the Week 1 concepts of information security governance by requiring you to analyse governance structures, compare recognised governance approaches, evaluate a major governance failure, and apply governance principles to complex organisational scenarios. The emphasis is on governance judgement, business alignment, accountability, oversight, and evidence-based recommendations.

Learning Objectives

- Analyse information security governance structures and evaluate their effectiveness.
- Compare major governance and information security management frameworks and justify an appropriate selection.
- Apply governance principles to realistic organisational and regulatory scenarios.
- Evaluate the alignment between information security governance and business objectives.
- Develop practical recommendations that strengthen accountability, oversight, risk management, and board engagement.

General Instructions

Complete all four parts. Submit one professionally structured document. Your work should demonstrate analysis and judgement rather than merely reproduce definitions from course materials.

- Use clear headings that correspond to Parts 1-4 and the task numbers below.
- Support major claims and recommendations with appropriate course concepts and credible references.
- Use tables, diagrams, governance charts, or RACI matrices where they improve clarity.
- Where an assumption is necessary, state it explicitly and explain why it is reasonable.
- Use professional information security governance terminology and write for an organisational decision-making audience.

Part 1 - Governance Structure Analysis (25 points)

Scenario: You are a security consultant engaged by TechCorp, a mid-sized technology company with approximately 500 employees. The company has grown rapidly and is concerned that its information security governance has not matured at the same pace. TechCorp is also planning international expansion within the next year.

Current situation:

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

- Information security is managed within the IT department, and the IT Director makes most security decisions.
- There is no formal security committee or governance body.
- The Board receives only a brief security update once per year.
- Security policies exist but are outdated and inconsistently followed.
- Security incidents are handled reactively, without a formal governance or escalation process.

Tasks:

1. Identify at least five specific weaknesses in TechCorp's current information security governance approach. For each weakness, explain:
 - the governance issue;
 - the potential business impact; and
 - how the weakness could affect the planned international expansion.
2. Design an improved information security governance structure for TechCorp. Your proposed design must include:
 - a governance organisational chart showing key roles and reporting relationships;
 - the key governance bodies or committees and their mandates;
 - defined responsibilities for major governance roles;
 - decision-making, escalation, and oversight processes;
 - a recommended approach to Board involvement and reporting.
3. Explain how your proposed structure aligns with at least three core principles of effective information security governance covered in the course.

Part 2 - Framework Comparison and Selection (25 points)

Scenario: The CIO of MedSecure, a healthcare organisation with approximately 2,000 employees operating in three states, is considering the adoption of a formal security governance framework. The organisation handles sensitive patient information and must satisfy HIPAA-related compliance obligations. The CIO has asked you to evaluate COBIT and ISO/IEC 27001.

Tasks:

4. Create a detailed comparison table of COBIT and ISO/IEC 27001. At minimum, compare:
 - scope and primary focus;
 - structure and major components;
 - governance approach;
 - implementation and certification considerations;
 - control selection and risk management;
 - strengths and limitations;
 - regulatory alignment, including HIPAA considerations;
 - resource requirements.
5. Recommend the framework, or combination of frameworks, that is most appropriate for MedSecure. Justify your recommendation by addressing:
 - healthcare-sector requirements;
 - MedSecure's size and complexity;
 - ability to support HIPAA compliance;
 - implementation challenges;
 - long-term sustainability and organisational evolution.

6. Develop a high-level implementation roadmap for your recommendation, including:

- implementation phases;
- critical success factors;
- likely challenges and mitigation measures;
- resource requirements;
- realistic timeline considerations.

Part 3 - Case Study Analysis: Equifax Data Breach (30 points)

Scenario: In 2017, Equifax suffered a major data breach that exposed the personal information of approximately 147 million people. The incident involved an unpatched Apache Struts vulnerability in an online dispute portal and became a prominent example of security governance failure.

Key facts provided for this assignment:

- Equifax was notified of the vulnerability in March 2017 but affected systems were not successfully patched.
- The breach occurred between May and July 2017 and was discovered on 29 July 2017.
- Public disclosure was made on 7 September 2017.
- The Chief Security Officer and Chief Information Officer resigned shortly after disclosure.
- Investigations identified failures including inadequate vulnerability management, poor network segmentation, and expired SSL certificates.
- The incident resulted in a settlement of up to \$575 million with the FTC, CFPB, and U.S. states.
- Congressional scrutiny highlighted unclear security accountability and inadequate Board oversight.

Tasks:

7. Analyse the Equifax breach from an information security governance perspective. Identify and explain at least five governance failures. For each failure, state:

- the specific governance issue;
- how it contributed to the breach or increased its impact;
- the governance principle or good practice that was not adequately applied.

8. Assume you were the CISO before the breach. Describe the governance structures, processes, and controls you would have established to reduce the likelihood or impact of the incident. Address:

- governance bodies and responsibilities;
- accountability mechanisms;
- risk management processes;
- Board reporting and oversight;
- policy enforcement;
- vulnerability management governance.

9. Discuss the wider governance lessons arising from the incident, including:

- changes in regulatory expectations;
- evolution of Board involvement in cyber oversight;
- executive accountability;
- lessons for organisations with similar risk profiles.

Part 4 - Governance Principles Application (20 points)

Scenario: You are the newly appointed CISO of GlobalFinance, a multinational financial services organisation with approximately 15,000 employees across 20 countries. The organisation is decentralised, with significant

autonomy at regional level. The CEO has asked you to establish governance principles that can be applied consistently across the organisation while accommodating legitimate regional differences.

Tasks:

10. Develop 7-10 information security governance principles for GlobalFinance. For each principle:
 - state the principle clearly and concisely;
 - explain its importance in a financial-services environment;
 - describe how it would be applied in practice;
 - identify likely implementation challenges in a decentralised organisation.
11. Explain how your proposed principles balance the following competing needs:
 - global consistency and local flexibility;
 - security requirements and business agility;
 - compliance obligations and innovation;
 - centralised oversight and distributed responsibility.
12. Design a governance mechanism for maintaining adherence to the principles across the organisation. Address:
 - how adherence will be measured and reported;
 - accountability at different organisational levels;
 - how exceptions or conflicts will be handled;
 - how the principles will be reviewed and continuously improved.

Submission Requirements

Requirement	Standard
Submission format	One DOCX or PDF file submitted through the ICDFA E-Campus.
Structure	Use Parts 1-4 as the main section headings. Include tables/diagrams where appropriate.
Recommended length	Approximately 3,000-4,000 words, excluding tables, diagrams, references, and appendices.
Referencing	Use APA-style citations for external sources and include a reference list.
File name	GRC102_Assignment1_StudentName_RegistrationNumber.pdf (or .docx).
Deadline	11 September 2026 at 11:59 PM WAT.

Grading Rubric

Assessment Component	Key Grading Focus	Points
Part 1 - Governance Structure Analysis	Identification of governance weaknesses; business impact analysis; quality and practicality of proposed governance structure; alignment with governance principles.	25
Part 2 - Framework Comparison and Selection	Accuracy and depth of comparison; quality of recommendation; healthcare and compliance considerations; implementation roadmap.	25

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

Assessment Component	Key Grading Focus	Points
Part 3 - Equifax Governance Case Study	Depth of governance-failure analysis; preventative governance approach; Board and executive accountability; application of governance concepts.	30
Part 4 - Governance Principles Application	Quality of governance principles; handling of competing organisational needs; effectiveness of proposed adherence and improvement mechanism.	20
TOTAL		100

Academic Integrity and Responsible Use of AI

Your submission must represent your own analysis and judgement. Cite all external sources appropriately. Where generative AI or other AI-assisted tools are permitted by the course or institutional policy, they may support brainstorming, language refinement, or research organisation, but they must not replace your independent analysis. You remain responsible for the accuracy of every statement submitted and should disclose AI assistance when required by ICDFA policy. Plagiarism, fabrication of sources, or submission of work that is not your own may result in action under the ICDFA Academic Integrity Policy.

Submission deadline: Friday, 11 September 2026 at 11:59 PM WAT via the ICDFA E-Campus.